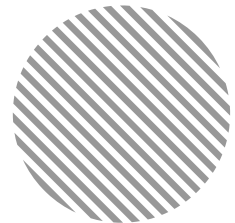


**Ubuntu Innovations
(Pty) Ltd**



System Administration & Cybersecurity

Prepared by :
Khusela Ikamva Tech

Table of Contents

1. Introduction	3
1.1 Purpose of the Report.....	3
1.2 Scope.....	3
1.3 Approach.....	4
1.4 Key Assumptions	4
2. Backup and Disaster Recovery Plan	5
2.1 Objectives.....	5
2.2 Data Classification.....	5
2.3 The 3-2-1-1 Backup Rule	5
2.4 Backup Schedule	6
2.5 Encryption and Security of Backups.....	6
2.6 Disaster Recovery Procedures	6
2.7 Testing and Assurance	7
3. Cybersecurity Policy	8
3.1 Acceptable Use	8
3.2 Identity and Access Management.....	8
3.3 Password and Authentication Standards.....	8
3.4 Device and Endpoint Security	9
3.5 Network Security.....	9
3.6 Data Protection and Handling.....	9
3.7 Email, Web and Messaging	9
3.8 Third-Party and Vendor Management.....	10
3.9 Policy Governance.....	10
4. Risk Assessment Matrix	11
4.1 Risk Scoring Key	11
4.2 Top Risks	11
4.3 Risk Treatment	12
5. Incident Response Plan	13
5.1 The Incident Response Team (IRT).....	13
5.2 Incident Severity Levels.....	13
5.3 Response Lifecycle	13
Phase 1 — Preparation	13

Phase 2 — Detection and Analysis.....	14
Phase 3 — Containment	14
Phase 4 — Eradication	14
Phase 5 — Recovery.....	14
Phase 6 — Lessons Learned	14
5.4 Worked Example — Ransomware Detected on a Finance Workstation	14
6. Security Awareness Training Outline	16
6.1 Training Objectives.....	16
6.2 Training Programme Structure	16
6.3 Sample 30-Minute Induction Session Agenda	16
6.4 Measuring Effectiveness	17
6.5 Reinforcement and Culture.....	17
7. Conclusion	18

1. Introduction

Ubuntu Innovation (Pty) Ltd operates in an increasingly digital environment where the confidentiality, integrity and availability of company information are central to our ability to serve clients, retain trust and remain competitive. As a team, we recognise that our data, systems, intellectual property and the personal information of our employees and customers are among our most valuable assets. The loss, theft or compromise of any of these would have a direct impact on our operations, reputation, regulatory standing and bottom line.

This report has been prepared collaboratively by the IT, Risk and Operations team as part of the company's "Protect the Company" initiative. Our brief was clear: design a practical, end-to-end strategy that strengthens how we back up our data, secure our systems and respond when something goes wrong. The intention is not to introduce technology for its own sake, but to ensure that every reasonable step has been taken to safeguard the business against the threats most likely to affect a South African mid-sized technology company in 2026.

1.1 Purpose of the Report

The purpose of this report is to consolidate, in a single working document, the policies, plans and procedures that together form Ubuntu Innovation's information security and business continuity posture. It is meant to serve three audiences at once: executive management, who require a clear summary of risks and controls; line managers, who need actionable procedures for their teams; and operational staff, who must understand their day-to-day responsibilities.

1.2 Scope

This report covers five interconnected areas, each of which has been developed as a stand-alone section that can also be read in isolation:

1. A Backup and Disaster Recovery Plan covering data classification, backup schedules, storage locations, retention and recovery testing.
2. A Cybersecurity Policy setting out the technical and behavioural controls expected of all employees, contractors and third parties.
3. A Risk Assessment Matrix identifying the most material information security risks, with likelihood, impact and mitigation actions.
4. An Incident Response Plan describing how we detect, contain, eradicate, recover from and learn from security incidents.
5. A Security Awareness Training Outline designed to build a security-conscious culture across every department.

1.3 Approach

In preparing this report we reviewed our current IT environment, interviewed staff across departments, benchmarked against widely accepted frameworks such as ISO/IEC 27001 and the NIST Cybersecurity Framework, and considered our obligations under the Protection of Personal Information Act (POPIA). Where existing controls are working, we have documented them; where gaps were identified, we have proposed specific, costed and time-bound improvements.

1.4 Key Assumptions

- All Ubuntu Innovation staff use company-issued devices for company work and bring-your-own-device usage is limited and managed.
- The company maintains a primary office network, a small server room and a mix of cloud-hosted services (Microsoft 365, customer CRM, code repositories).
- Internet connectivity is provided by a single primary fibre line with an LTE failover.
- Management has indicated willingness to fund security investments that are clearly justified by risk reduction.

2. Backup and Disaster Recovery Plan

Our backup and disaster recovery (DR) plan exists to ensure that, no matter what happens — accidental deletion, hardware failure, ransomware, fire, flood or theft — Ubuntu Innovation can recover its critical data and resume operations within a defined and acceptable timeframe. This section sets out what we back up, where we store it, how often, how long we keep it and how we prove that the backups work.

2.1 Objectives

- **Recovery Time Objective (RTO):** critical systems must be restored within 4 hours; non-critical systems within 24 hours.
- **Recovery Point Objective (RPO):** no more than 24 hours of data loss for any critical system, and no more than 1 hour for transactional databases.
- **Resilience:** no single event - including the total loss of the primary office — should be capable of permanently destroying company data.
- **Compliance:** backup practices must satisfy POPIA requirements regarding the safeguarding and retention of personal information.

2.2 Data Classification

Not all data carries the same value or sensitivity. We classify company data into four tiers, and our backup frequency and retention are determined by this classification:

Tier	Examples	Backup Frequency	Retention
Critical	Customer database, financial records, source code, signed contracts	Continuous / hourly	7 years
Important	Email, shared drives, project files, HR records	Daily	3 years
Operational	Workstation user profiles, internal wikis, meeting notes	Weekly	12 months
Transient	Cache, temp files, downloaded media	Not backed up	N/A

2.3 The 3-2-1-1 Backup Rule

Ubuntu Innovation applies the industry-standard 3-2-1-1 rule. This means that at any given moment we maintain at least three copies of every critical data set, on two different types of media, with one copy stored off-site and one copy held in immutable (write-once) storage that cannot be altered or deleted by ransomware.

- **Copy 1 - Production:** the live data on our servers and cloud platforms.

- **Copy 2 - Local NAS:** an on-premises Network-Attached Storage device in the server room, receiving incremental backups every night.
- **Copy 3 - Cloud:** encrypted weekly full backups replicated to a reputable cloud provider in a geographically separate region.
- **Copy 4 - Immutable archive:** monthly snapshots written to object-lock storage that cannot be modified for 90 days, protecting against ransomware that targets backups themselves.

2.4 Backup Schedule

Backup Type	Frequency	Destination	Owner
Database transaction logs	Every 60 minutes	Local NAS + cloud	Database Administrator
Full file server backup	Daily, 20:00	Local NAS	IT Support Lead
Microsoft 365 (mail, OneDrive, SharePoint)	Daily	Third-party SaaS backup	IT Support Lead
Full server image	Weekly, Sunday 22:00	Encrypted cloud	Systems Administrator
Immutable archive snapshot	Monthly, 1st of month	Object-lock cloud storage	IT Manager

2.5 Encryption and Security of Backups

All backup data is encrypted in transit using TLS 1.2 or higher, and at rest using AES-256. Encryption keys are managed in a dedicated key vault, with access restricted to two named senior administrators. Backup media taken off-site for any reason are logged in and out of the server room by the duty IT officer.

2.6 Disaster Recovery Procedures

In the event of a disaster, the following sequence is followed. The IT Manager (or delegate) is the designated Recovery Coordinator and has the authority to declare a disaster and initiate the DR plan.

6. Declare the incident: confirm scope, notify executive management and activate the incident response team.
7. Assess: determine which systems are affected and whether the primary site is usable.
8. Failover: redirect critical services (email, CRM, customer portal) to their cloud-hosted DR equivalents.
9. Restore: rebuild affected servers from the most recent clean backup, working from highest to lowest tier.
10. Verify: confirm data integrity, application functionality and that no malware persists.
11. Communicate: keep staff, customers and, where required, regulators informed throughout.

-
12. Return to normal: once the primary environment is stable and verified, fail services back during a planned maintenance window.

2.7 Testing and Assurance

A backup is only as good as the last successful restore. We therefore perform tiered testing on a defined cadence:

- **Monthly:** random-sample file restores from the local NAS, performed by the IT Support Lead and logged.
- **Quarterly:** full database restores to an isolated test environment, verified by the Database Administrator.
- **Annually:** a full disaster recovery simulation covering total loss of the primary site, including measurement of actual RTO and RPO against the targets above.

Results of each test are recorded in the Backup Test Register and reviewed by the IT Manager. Any failures trigger a corrective action with a 14-day remediation deadline.

3. Cybersecurity Policy

This policy sets out the minimum standards of behaviour and the technical controls that protect Ubuntu Innovation's information assets. It applies to every employee, contractor, intern and third-party service provider who accesses our systems or data. By using a company device or account, individuals agree to abide by this policy. Non-compliance may result in disciplinary action up to and including dismissal, and in serious cases criminal or civil proceedings.

3.1 Acceptable Use

- Company devices and accounts are provided for business purposes; limited personal use is permitted provided it is lawful, does not interfere with work and does not consume excessive resources.
- Users may not install unauthorised software, disable security tools, or connect personal storage devices without IT approval.
- Confidential information must never be sent to personal email accounts or uploaded to personal cloud services.

3.2 Identity and Access Management

- **Unique accounts:** every user has a unique, named account; shared logins are prohibited.
- **Least privilege:** users receive only the access they need to perform their role, reviewed quarterly by line managers.
- **Privileged access:** administrator accounts are separate from day-to-day accounts and require additional approval.
- **Joiners, movers, leavers:** HR notifies IT of all role changes; access is granted, modified or revoked within one business day.

3.3 Password and Authentication Standards

- Passwords must be at least 14 characters long, ideally a passphrase, and must not be reused across systems.
- Multi-Factor Authentication (MFA) is mandatory for email, VPN, administrator accounts and any cloud service holding company data.
- Passwords are stored only in the company-approved password manager; writing passwords on paper or in unencrypted files is prohibited.
- Default passwords on any new device or system must be changed before the device is placed into service.

3.4 Device and Endpoint Security

- All laptops and desktops run the company-managed endpoint detection and response (EDR) agent, with tamper protection enabled.
- Full-disk encryption (BitLocker for Windows, FileVault for macOS) is enforced on every portable device.
- Operating system and application security updates are applied automatically within 14 days of release; critical patches within 72 hours.
- Screens must lock automatically after 5 minutes of inactivity, and users must lock their screens manually when leaving a workstation.

3.5 Network Security

- The corporate Wi-Fi is segmented from a separate guest network; guests never access the corporate LAN.
- Remote access to internal systems requires the company VPN with MFA.
- Inbound firewall rules follow a default-deny posture; exceptions are documented and reviewed quarterly.
- Intrusion detection logs are reviewed daily by the IT Support Lead and weekly by the IT Manager.

3.6 Data Protection and Handling

- Personal information processed by Ubuntu Innovation is handled in accordance with POPIA, including the lawful basis for processing and the data subject's rights.
- Confidential documents must be classified using the four-tier scheme set out in Section 2.2 and labelled accordingly.
- Sensitive data shared externally must be encrypted (password-protected archives, secure file transfer, or encrypted email).
- Printed confidential material must be collected from printers promptly and shredded when no longer required.

3.7 Email, Web and Messaging

- All inbound and outbound email passes through an anti-spam and anti-phishing gateway with attachment sandboxing.
- Users must not click on suspicious links or open unexpected attachments; suspected phishing should be reported via the 'Report Phishing' button in Outlook.
- Use of personal messaging apps for company business is discouraged; where unavoidable, no confidential data may be shared.

3.8 Third-Party and Vendor Management

- Any new vendor with access to company data must complete a security questionnaire and sign a Data Processing Agreement.
- Vendor access is time-bound, logged and reviewed every six months.
- Critical vendors must demonstrate ISO 27001 certification or an equivalent recognised standard.

3.9 Policy Governance

This policy is owned by the IT Manager and approved by the Executive Committee. It is reviewed annually, or sooner if there is a material change in the threat landscape, regulatory environment or company operations. All staff acknowledge the policy on joining and at each annual refresh.

4. Risk Assessment Matrix

To prioritise our security investments, the team conducted a structured risk assessment. Each identified risk was scored on likelihood (1–5) and impact (1–5); the product of the two gives a risk rating from 1 (negligible) to 25 (critical). The matrix below summarises the top risks currently facing Ubuntu Innovation, together with the existing controls and the additional mitigation actions we recommend.

4.1 Risk Scoring Key

- 1–5 (Low): accept and monitor.
- 6–12 (Medium): mitigate with reasonable controls; review quarterly.
- 13–19 (High): mitigate as a priority within 90 days; report to executive.
- 20–25 (Critical): immediate executive attention and remediation.

4.2 Top Risks

Risk	Likelihood	Impact	Rating	Mitigation
Phishing / business email compromise	5	4	20 — Critical	Advanced email filtering with attachment sandboxing; mandatory quarterly phishing simulations; MFA on all accounts; finance dual-approval rule for any payment instruction received by email.
Ransomware	3	5	15 — High	Immutable backups; EDR with behavioural detection; network segmentation; least-privilege access; tested DR plan with quarterly restore drills.
Insider data theft	2	5	10 — Medium	Data Loss Prevention on email and USB; activity logging on confidential repositories; exit checklist with same-day revocation; mandatory leave for sensitive roles.
Lost or stolen laptop	4	3	12 — Medium	Full-disk encryption; remote wipe via mobile device management; asset register; SAPS case opened for every theft.
Cloud service misconfiguration	3	4	12 — Medium	Cloud Security Posture Management tooling; baseline secure configuration; quarterly configuration review; change control for all tenant-level settings.
Power outage / load shedding	5	2	10 — Medium	UPS on all servers and network equipment; generator with weekly test run; documented graceful shutdown procedure.
Third-party / supply chain breach	3	4	12 — Medium	Vendor risk questionnaire; contractual security obligations; restricted vendor access; monitoring of vendor security bulletins.

Risk	Likelihood	Impact	Rating	Mitigation
DDoS attack on customer portal	2	4	8 — Medium	Cloud-based DDoS protection in front of public services; rate limiting; runbook for traffic surge events.
POPIA non-compliance	3	4	12 — Medium	Appointed Information Officer; data inventory; consent and retention controls; breach notification procedure aligned to Section 22.

4.3 Risk Treatment

For each risk rated Medium or higher, an action owner and target completion date has been assigned in the Risk Register, which is reviewed monthly by the IT Manager and quarterly by the Executive Committee. Residual risks that fall within the Board's stated risk appetite are formally accepted and documented.

5. Incident Response Plan

Despite the controls described in this report, security incidents remain a matter of when, not if. The Incident Response Plan (IRP) ensures that when one occurs, Ubuntu Innovation responds in a calm, structured and effective way that minimises damage, preserves evidence and restores normal operations as quickly as possible.

5.1 The Incident Response Team (IRT)

- **Incident Commander - IT Manager:** owns the response, makes containment decisions and authorises external communication.
- **Technical Lead - Systems Administrator:** coordinates investigation, containment and recovery activities.
- **Communications Lead - Marketing Manager:** drafts internal and external messaging under guidance from the Incident Commander.
- **Legal & Compliance Lead - Company Secretary:** advises on regulatory obligations, including POPIA breach notifications.
- **HR Lead - HR Manager:** manages any employee-related aspects, including suspected insider incidents.

5.2 Incident Severity Levels

Level	Definition	Response Target
SEV-1 Critical	Active ransomware, confirmed data breach, full system outage	IRT mobilised within 15 minutes; executive notified within 30 minutes
SEV-2 High	Targeted phishing campaign, single-user account compromise, partial outage	IRT mobilised within 1 hour; resolved within 24 hours
SEV-3 Medium	Malware detected and contained by EDR, lost laptop, suspicious activity	Investigated within 1 business day
SEV-4 Low	Policy violation, spam reaching inbox, minor misconfiguration	Logged and addressed in normal IT workflow

5.3 Response Lifecycle

Our response follows the six-phase NIST lifecycle, adapted to our environment:

Phase 1 — Preparation

- Maintain up-to-date contact lists for the IRT, executives, vendors and law enforcement (SAPS Cybercrime Unit, Hawks).

-
- Pre-stage forensic tools, clean laptops and out-of-band communication (a private WhatsApp group hosted on personal devices for use when corporate email is unavailable).
 - Maintain a retainer with an external incident response firm for surge capacity.

Phase 2 — Detection and Analysis

- Alerts originate from EDR, email gateway, firewall, user reports or external notification.
- The on-call IT engineer triages the alert within 15 minutes and assigns a severity level.
- All actions are logged in the Incident Log from the moment the incident is declared.

Phase 3 — Containment

- Short-term: isolate affected devices from the network (disconnect cable, disable Wi-Fi, quarantine via EDR).
- Account-level: force password resets, revoke active sessions, disable compromised accounts.
- Long-term: apply firewall rules, block malicious indicators across the estate.

Phase 4 — Eradication

- Identify and remove the root cause: malicious files, persistence mechanisms, attacker accounts.
- Patch the exploited vulnerability before bringing systems back online.
- Where compromise is suspected at OS level, reimage rather than clean.

Phase 5 — Recovery

- Restore from a verified clean backup taken before the incident window.
- Monitor restored systems intensively for 14 days for signs of re-infection.
- Phased return to service, lowest-risk systems first.

Phase 6 — Lessons Learned

- Within 10 business days the IRT holds a blameless post-incident review.
- Findings are written up in a Post-Incident Report including timeline, root cause, impact, what worked, what did not, and concrete improvement actions with owners and dates.
- The Risk Register and this report are updated where necessary.

5.4 Worked Example — Ransomware Detected on a Finance Workstation

13. EDR alert at 09:14: 'Ransom note created by suspicious process' on workstation FIN-07. On-call engineer acknowledges within 5 minutes.
14. Severity declared SEV-1. Incident Commander activates the IRT and notifies the CEO and CFO.
15. Containment: FIN-07 isolated via EDR; the entire finance VLAN is segmented from the rest of the network; the user's account is disabled and all active sessions revoked.

-
16. Scope assessment: log review identifies one mapped share that the workstation could write to; that file server is taken offline as a precaution; immutable backups are confirmed intact.
 17. Eradication: FIN-07 is reimaged from a known-good gold image; the patch for the exploited vulnerability (a malicious macro in a Word document) is rolled out to all endpoints; macro execution from internet-sourced documents is blocked via Group Policy.
 18. Recovery: the affected file server is restored from the previous night's backup; checksums verified; users notified that any work done between 17:00 yesterday and the incident may need to be re-entered.
 19. Communications: an internal note is issued to all staff explaining the incident in plain language and reminding them of phishing reporting procedures.
 20. Regulatory: the Information Officer confirms that no personal information was exfiltrated; a precautionary record is kept in case POPIA notification becomes necessary.
 21. Lessons learned (held 7 days later): macro policy gap closed; phishing simulation focused on macro lures scheduled; backup immutability validated as the single most important control in limiting damage.

6. Security Awareness Training Outline

Technology alone cannot keep Ubuntu Innovation safe. The overwhelming majority of successful attacks begin with a person clicking a link, approving a fraudulent payment, plugging in an unknown USB stick. A workforce that is alert, sceptical and confident in reporting suspicious activity is the single most cost-effective security control available to us. This section describes how we will build and sustain that culture.

6.1 Training Objectives

- Every employee understands the most common threats relevant to their role and can recognise them in practice.
- Every employee knows what to do - and what not to do when something looks suspicious.
- Reporting a suspected incident is seen as a positive contribution, never as a fault to be hidden.
- Security expectations are reinforced often enough to remain front-of-mind, without becoming background noise.

6.2 Training Programme Structure

Component	Audience	Frequency	Format
Induction session	New joiners	Within first week	60-minute facilitated session + policy sign-off
Annual refresher	All staff	Once per year	E-learning module + short assessment
Phishing simulations	All staff	Quarterly	Realistic test emails; instant micro-learning for those who click
Role-based deep dives	Finance, HR, IT, Developers	Twice yearly	Workshop tailored to threats specific to the role
Security moments	All meetings	Ongoing	3-minute slot at the start of departmental meetings
Executive briefing	Executive Committee	Quarterly	Threat landscape, incident trends, key metrics

6.3 Sample 30-Minute Induction Session Agenda

- **00:00 – 00:03 Welcome and why this matters:** real South African case studies of companies that were materially harmed by a single click.
- **00:03 – 00:10 Spotting phishing:** sender mismatch, urgency cues, suspicious links, attachments — live demonstration of a real phish.
- **00:10 – 00:16 Password and account hygiene:** passphrases, the company password manager, MFA enrolment walkthrough.

-
- **00:16 – 00:21 Data handling:** classification scheme, sharing rules, what never leaves the company.
 - **00:21 – 00:26 If something goes wrong:** how to report, who to contact, the 'no blame for honest mistakes' principle.
 - **00:26 – 00:30 Questions and policy acknowledgement signing.**

6.4 Measuring Effectiveness

- Phishing simulation click rate, tracked over time and by department.
- Time-to-report for simulated phishing emails - we want this trending down.
- Completion rate of annual e-learning, target 100% within the cycle.
- Number of voluntarily reported suspicious emails per month — higher is better, indicating a vigilant culture.
- Reduction in real incidents traceable to user behaviour, year on year.

6.5 Reinforcement and Culture

Awareness is built through repetition in small doses rather than long annual lectures. We will use short monthly bulletins, posters in common areas, and a dedicated channel on the company intranet to keep security visible. Managers will be expected to model the behaviours expected of their teams. Recognition for staff who report genuine threats will be built into the existing employee recognition programme.

7. Conclusion

Protecting Ubuntu Innovation (Pty) Ltd is not a one-off project but an ongoing discipline. The five pillars set out in this report - disciplined backups, a clear cybersecurity policy, an honest risk assessment, a tested incident response plan and continuous awareness training work together as a single, coherent programme. No one of them alone is sufficient; together they provide defence in depth that significantly reduces both the likelihood and the impact of the security events most likely to affect us.

As a team we are realistic. We know that determined attackers will continue to evolve their methods, that load shedding and connectivity issues will continue to test our resilience, and that human error will always be part of the equation. The objective is not to achieve a state of perfect security, which does not exist, but to ensure that when something goes wrong, we recover quickly, learn openly, and emerge stronger.

We are also pragmatic. The recommendations in this report have been kept proportionate to the size, risk profile and resources of Ubuntu Innovation. Where investment is required — for example in immutable backup storage, EDR licences, or external incident response retainers — the cost has been weighed against the potential cost of the event it prevents. In every case the business case is clear.